

Reg. No.: E/22/364

The mini project is based on a Medico-Legal Information Management System designed to manage post-mortem cases, forensic investigations, evidence handling, court proceedings, and related medical and legal workflows. The system involves multiple stakeholders including doctors, staff, police, and court officials.

[illegible]

1. POLICE_STATION: POLICE_STATION(StationID [PK], StationName, District, ContactNo)
2. DECEASES: DECEASES(DeceasedID [PK], FullName, Age, Sex, PlaceOfDeath, EventDeathID [FK])
3. CASE_TYPE: CASE_TYPE(CaseTypeID [PK], TypeName, TypeForm, Module)
4. REFERRAL_SOURCE: REFERRAL_SOURCE(SourceID [PK], SourceName, TypeForm, SourceType)
5. DOCTOR: DOCTOR(DoctorID [PK], FullName, SLMCNo, Designation, ContactNo, Email)
6. PATIENT: PATIENT(PatientID [PK], FullName, NIC, DOB, Gender, Address, ContactNo, Email, HealthConditions, HospitalNo)
7. USER: USER(UserID [PK], Username, PasswordHash, Role, LinkedID, IsActive)
8. STAFF: STAFF(StaffID [PK], FullName, NIC, DOB, Role, ContactNo, Email, LinkedID [FK])
9. MANNER OF DEATH: MANNER OF DEATH(MannerID [PK], MannerName, MannerCategory)

10. INVESTIGATION_TYPE: INVESTIGATION_TYPE(InvTypeID [PK], TypeName, DefaultLab, Module)
11. PM_CASE: PM_CASE(PMCaseID [PK], PMCaseStatus, DeceasedID [FK], SourceID [FK], CaseTypeID [FK], StatusID [FK], RequestedDate, ReasonBy, PMNecessity, PMDate, ReportDate, Status)
12. MLZT_CASE: MLZT_CASE(CaseID [PK], MLZTNo, PatientID [FK], DoctorID [FK], CaseTypeID [FK], StatusID [FK], SourceID [FK], EventDateTime, EventPlace, AlcoholResult, DrugResult, ToxicologyFindings, DocFindings, Status)
13. INJURY: INJURY(InjuryID [PK], CaseID [FK], InjuryType, WeaponType, Description, BodyLocation, Size, Shape)
14. INVESTIGATION: INVESTIGATION(InvestigationID [PK], CaseID [FK], CaseAttribute, InvTypeID [FK], Result, ResultDate, RequestedBy)
15. EVIDENCE: EVIDENCE(EvidenceID [PK], CaseID [FK], CaseAttribute, SpecimenType, CollectedDateTime, CollectedBy, StorageLocation)
16. CUSTODY_LOG: CUSTODY_LOG(LogID [PK], EvidenceID [FK], HandedBy, ReceivedBy, TransferDateTime, Purpose)
17. PM_REPORT: PM_REPORT(PMReportID [PK], PMCaseID [FK], SignedBy [FK], NurseID [FK], COD_a, COD_b, COD_c, COD_d, IssuedDate, ExternalFindings, InternalFindings, SignDate, DispatchDate, Status)
18. RECEIPT_CERT: RECEIPT_CERT(ReceiptID [PK], ReportID [FK], ReportPosition, Courts, PaidDate, ReceivedDate)
19. AUDIT_LOG: AUDIT_LOG(LogID [PK], UserID [FK], Action, TableAffected, Timestamp, IPAddress)
20. NOTIFICATION: NOTIFICATION(NotifID [PK], RecipientID [FK], Message, Type, Timestamp, IsRead)
21. COURT: COURT(CourtID [PK], CourtName, CourtType, Location)
22. COURT_SUMMONS: COURT_SUMMONS(SummonsID [PK], CaseID [FK], CourtID [FK], TrialDate, ExecutionDate, SignedDate, DispatchDate, Status)
23. ML_REPORT: ML_REPORT(ReportID [PK], CaseID [FK], SignedBy [FK], Benefits, MagistrateDetails, DueDate, SignedDate, DispatchDate, Status)
24. BILL_REPORT: BILL_REPORT(BillID [PK], CaseID [FK], SignedBy [FK], Benefits, MagistrateDetails, DueDate, SignedDate, DispatchDate, Status)
25. MANNER_OF_DEATH_CASE: MANNER_OF_DEATH_CASE(PMReportID [FK], MannerID [FK], PRIMARY KEY(PMReportID, MannerID))

Database Security Goals

Goal 1: Protect Sensitive Information

The system handles highly sensitive medico-legal data. The following tables and attributes contain sensitive information.

- USER table: Contains Username, PasswordHash, Role, LinkedID, and IsActive. Passwords must be stored using strong hashing algorithms, not in plain text.
- PATIENT table: Contains FullName, NIC, DOB, Gender, Address, ContactNo, Email, HealthConditions, HospitalNo and all personally identifiable information (PII).
- DECEASES table: Contains FullName, Age, Sex, PlaceOfDeath, and EventDeathID which are sensitive deceased personal data.
- PM_REPORT and ML_REPORT tables: Contain forensic findings, cause of death details (COD_a, COD_b, COD_c, COD_d), internal/external findings, and signed report data.
- BILL_REPORT table: Contains financial/billing information related to medico-legal services.
- EVIDENCE and CUSTODY_LOG tables: Contain forensic evidence details and chain of custody records.

Goal 2: Prevent Unauthorized Access

The system identifies the following user roles based on the USER table and related entity tables.

User Role	Table Accessible	Permissions
Administrator	All tables	Full CRUD, user management, audit log viewing
Doctor / Pathologist	DOCTOR, PM_CASE, MLZT_CASE, PM_REPORT, ML_REPORT, PATIENT	Read/Write on cases and reports assigned to them
Staff	STAFF, INVESTIGATION, EVIDENCE, CUSTODY_LOG, INJURY	Read/Write on investigations and evidence
Police Officer	POLICE_STATION, PM_CASE, INJURY, COURT_SUMMONS	Read-only on case status; submit injury/case requests
Court Official	COURT, COURT_SUMMONS, ML_REPORT, BILL_REPORT	Read-only on court-related reports and summons
Billing Staff	BILL_REPORT, RECEIPT_CERT	Read/Write on billing and receipts only

Goal 3: Maintain Accurate Data

The database design enforces data integrity through the following mechanisms.

- **Primary Keys:** Every table has a unique primary key like PMCaseID, InvestigationID, EvidenceID preventing duplicate records.
- **Foreign Keys:** Relationships are enforced across tables as follows,
 - PM_CASE.DeceasedID → DECEASES.DeceasedID
 - PM_CASE.CaseTypeID → CASE_TYPE.CaseTypeID
 - MLZT_CASE.PatientID → PATIENT.PatientID
 - MLZT_CASE.DoctorID → DOCTOR.DoctorID
 - INVESTIGATION.CaseID → PM_CASE.PMCaseID
 - EVIDENCE.CaseID → PM_CASE.PMCaseID
 - CUSTODY_LOG.EvidenceID → EVIDENCE.EvidenceID
 - PM_REPORT.PMCaseID → PM_CASE.PMCaseID
- **NOT NULL Constraints:** Critical fields like PMCaseID, PatientID, DoctorID, UserID, and Status are put to be not null.
- **ENUM/CHECK Constraints:** Fields like Status in PM_CASE, INVESTIGATION, and PM_REPORT accept only valid predefined values like Pending, Active, Closed.
- **Timestamps:** CollectedDateTime in EVIDENCE, TransferDateTime in CUSTODY_LOG, and Timestamp in AUDIT_LOG auto-record accurate time of events.
- **Cascade Rules:** Deleting a case cascades appropriately to child records to maintain referential consistency.

- Unique Constraints: USER.Username and PATIENT.NIC are unique to prevent duplicate identity records.

Goal 4: Ensure Continuous Availability

To ensure the system remains available at all times:

- Full database backups will be scheduled daily, with incremental backups every few hours. Backups will be stored on separate servers and off-site storage.
- A master-slave PostgreSQL replication setup will be used so the replica can take over if the primary fails.
- Failover: Automated failover mechanisms will redirect traffic to the replica database within minutes of a primary failure.
- Tools like PgBouncer will manage database connections efficiently to handle concurrent users without performance degradation.
- Schema migrations via Flyway and maintenance tasks will be performed during off-peak hours to minimize downtime.
- AUDIT_LOG and CUSTODY_LOG tables will be stored on high-availability storage with redundancy to ensure forensic data is never lost.
- As recovery procedures, Point-in-time recovery (PITR) using WAL (Write-Ahead Logging) in PostgreSQL will allow restoration to any specific point in time in case of data corruption.

Goal 5: Detect and Respond to Attacks

The system uses several mechanisms to detect and respond to malicious activities.

- The AUDIT_LOG table automatically records every INSERT, UPDATE, DELETE, and SELECT on sensitive tables such as PM_REPORT, EVIDENCE, USER, and PATIENT. This provides a full audit trail.
- CUSTODY_LOG table tracks every transfer of evidence (HandedBy, ReceivedBy, Purpose, TransferDateTime), detecting any unauthorized movement of forensic evidence.
- The NOTIFICATION table (NotifID, RecipientID, Message, Type, Timestamp) can trigger alerts to administrators when anomalous activities are detected.
- The USER table's IsActive flag will be used to lock accounts after a configurable number of failed login attempts, preventing brute force attacks.
- Database-Level Triggers will be set on sensitive tables to write to AUDIT_LOG automatically on any modification.
- Database activity monitoring (DAM) tools will analyze query patterns and flag anomalies such as bulk data exports, access outside working hours, or access from unknown IP addresses.
- Any access attempt to PM_REPORT or ML_REPORT by unauthorized roles will be logged and an alert fired via the NOTIFICATION system.

Goal 6: Comply with Legal and Regulatory Requirements

As a medico-legal system operating within a healthcare and judicial context, compliance with data protection regulations is critical.

- Personal information in DECEASES (FullName, Age, PlaceOfDeath) and PATIENT (NIC, DOB, Address, HealthConditions) is restricted to authorized personnel only, complying with patient privacy laws.
- Authorized administrators can update PATIENT or STAFF records to correct errors, supporting the right to data accuracy.
- Data minimization is implemented by collecting only necessary data per table, for example, MLZT_CASE collects the minimum fields needed to link a patient, doctor, and case type.
- Medico-legal records such as PM_REPORT, ML_REPORT, and RECEIPT_CERT must be retained for legally mandated periods. The system will implement archival policies for old records while keeping them accessible for court use.
- The CUSTODY_LOG table ensures forensic evidence handling is fully documented, meeting judicial requirements for evidence admissibility.
- AUDIT_LOG provides proof of who accessed what data and when, supporting legal accountability requirements.
- The system design aligns with Sri Lanka's data protection frameworks and general international standards such as GDPR principles (data minimization, purpose limitation, storage limitation).

Recommendations for Improving Database Security

- Implement Column-Level Encryption for PATIENT.NIC, PATIENT.HealthConditions, and USER.PasswordHash using PostgreSQL's pgcrypto extension.
- Enable Row-Level Security (RLS) in PostgreSQL so doctors can only query cases assigned to them.
- Use database roles (CREATE ROLE) instead of granting privileges directly to user accounts.
- Implement Two-Factor Authentication (2FA) for Administrator and Doctor roles accessing sensitive reports.
- Set up automated alerting tied to the NOTIFICATION table for anomalous AUDIT_LOG entries.
- Regularly rotate database credentials and enforce strong password policies on all USER accounts.
- Penetration testing should be conducted periodically to identify SQL injection or privilege escalation vulnerabilities.
- Anonymize data in development/test environments. For this never use real PATIENT or DECEASES data outside production